

Jeune Élan

Dossier complet du système et analyse de viabilité pour l'administrateur

Projet : Jeune Élan (dépôt to-be-riche)

Contenu : fonctionnement, sécurité, viabilité financière

Version : 1.0 — 22 septembre 2026

Diffusion : usage interne de l'administrateur

Table des matières

Résumé exécutif.....	1
1. Objet, périmètre et méthode du dossier.....	2
1.1 Pourquoi ce dossier.....	2
1.2 Périmètre couvert et limites.....	2
1.3 Méthode.....	2
2. Présentation générale de la plateforme.....	2
2.1 Identité et concept.....	3
2.2 Stack technique et architecture.....	3
2.3 Données et monnaies internes.....	3
3. Parcours d'entrée : inscription, OTP et connexion.....	4
3.1 Création de compte.....	4
3.2 Vérification par code à usage unique (OTP).....	4
3.3 Connexion et gestion des sessions.....	4
4. Fonctionnement détaillé des modules.....	5
4.1 Tableau de bord du jeune (Étape 1).....	5
4.2 Missions rémunérées et validation par intelligence artificielle.....	5
4.3 Objectif 2 500 FCFA, caution et micro-prêts.....	6
4.4 Portefeuille, dépôts et retraits.....	6
4.5 Parrainage et niveaux d'investissement.....	6
4.6 Jeu, trading et arène.....	7
4.7 Chat, support et notifications.....	7
4.8 Guide, PWA et éléments annexes.....	7
4.9 Panel administrateur.....	8
5. Analyse de sécurité : failles identifiées et correctifs.....	8
5.1 Mécanismes de sécurité existants et efficaces.....	8
5.2 Failles identifiées, impact et correctifs.....	8

5.3 Plan de correction priorisé.....	9
6. Analyse de viabilité financière pour l'administrateur.....	9
6.1 Où l'argent entre — et où il ne rentre pas.....	9
6.2 Le problème structurel : un passif qui croît sans revenu.....	10
6.3 Scénarios d'évolution chiffrés.....	10
6.4 Risques réglementaires et réputationnels.....	11
6.5 Verdict : couler ou être rentable ?.....	11
7. Conclusions et plan d'action recommandé.....	12
Annexe : cartographie des modules et principales routes d'API.....	12

Remarque : cette table des matières est générée par champs. Après toute modification du document, faites un clic droit sur la table puis choisissez « Mettre à jour les champs » pour actualiser la pagination.

Résumé exécutif

Ce dossier décrit le fonctionnement complet de la plateforme « Jeune Élan » (dépôt GitHub to-be-riche), du parcours d'entrée à la connexion jusqu'aux moindres modules : missions rémunérées d'images, portefeuille multi-comptes, dépôts et retraits, caution, micro-prêts, parrainage, investissements, jeu, trading, chat, notifications et panel administrateur. Il a été établi exclusivement à partir de la lecture du code source (environ 80 routes d'API et une vingtaine d'écrans), sans extrapolation : chaque mécanisme décrit correspond à un fichier vérifiable du projet.

Deux analyses complètent la description. La première porte sur la sécurité : le système présente des mécanismes réels et bien pensés (jetons de session rotatifs, vérification par code à usage unique, validation des images par intelligence artificielle), mais souffre de deux failles critiques — un compte administrateur codé en dur dans le code source du dépôt public et des mots de passe stockés en clair — ainsi que de plusieurs vulnérabilités importantes (absence de limitation de débit sur les endpoints sensibles, cookie de session exposé aux scripts, base SQLite sans sauvegarde identifiée).

La seconde analyse répond à la question centrale posée par l'administrateur : le projet va-t-il couler ou être rentable sur le long terme ? La réponse factuelle est sans ambiguïté : en l'état, le modèle économique est structurellement déficitaire. Chaque image validée crée 25 FCFA de dette envers un jeune, chaque gain de roue, chaque bonus de parrainage et chaque rendement d'investissement de 5 % par jour créent du passif, sans qu'aucune source de revenu réelle (sponsor payant, commission, frais, publicité vendue) n'existe dans le code. À 500 jeunes actifs, la seule activité missions génère environ 31,9 millions de FCFA de passif par an. Le projet ne peut devenir rentable qu'en activant des revenus externes (partenariats de marques, frais de service, commissions) et en supprimant les paramètres explosifs, en particulier le rendement quotidien de 5 %. Les chapitres 5 et 6 détaillent les correctifs et les scénarios chiffrés.

1. Objet, périmètre et méthode du dossier

1.1 Pourquoi ce dossier

L'administrateur de la plateforme a exprimé trois besoins : disposer d'un document expliquant comment tous les aspects du site fonctionnent, pouvoir analyser le système pour identifier d'éventuelles failles, et évaluer si le projet risque de couler ou s'il peut être rentable sur le long terme. Ce dossier répond aux trois questions dans un document unique, pensé pour être lu progressivement : les chapitres 2 à 4 décrivent le système, le chapitre 5 traite la

sécurité, le chapitre 6 traite la viabilité financière et le chapitre 7 consolide les recommandations en un plan d'action priorisé.

1.2 Périmètre couvert et limites

Le périmètre couvre l'intégralité du code applicatif du dépôt : écrans (components/screens), routes d'API (app/api), bibliothèques métier (lib), schéma de base de données (prisma/schema.prisma), services annexes (mini-services) et éléments d'installation progressive (manifest, service worker). Le tableau de bord de l'utilisateur a été reconstruit récemment selon la spécification « Étape 1 » avec des données fictives destinées à être remplacées par les vraies données des API existantes ; cette transition est décrite au chapitre 4. En revanche, ce dossier ne couvre pas l'infrastructure d'hébergement effective (non présente dans le dépôt), les contrats commerciaux éventuels conclus hors code avec des marques, ni les obligations fiscales et comptables locales, qui relèvent d'un conseiller juridique et fiscal.

1.3 Méthode

La méthode est celle d'une revue de code statique guidée par les flux d'argent et les flux de données. Chaque affirmation du présent dossier a été vérifiée directement dans les fichiers concernés : lecture du schéma Prisma pour les soldes et conditions, lecture des routes d'authentification pour le cycle d'entrée, lecture des routes de missions, de prêts, de retraits, de jeu et d'investissement pour les règles métier, et tests fonctionnels dans un navigateur pour confirmer le comportement de l'interface. Les montants chiffrés du chapitre 6 sont des projections illustratives fondées sur les paramètres réels du code (25 FCFA par image, limite de 10 images par jour, taux de change interne), clairement signalées comme hypothèses.

2. Présentation générale de la plateforme

2.1 Identité et concept

« Jeune Élan » est une application financière et éducative destinée à un public de jeunes en Afrique de l'Ouest, précédemment nommée « Be Rich » / « To Be Rich » puis « Espace Jeunes ». Le concept affiché est résumé par la promesse d'accueil : « Créez. Gagnez. Empruntez. » Le jeune crée des visuels publicitaires à l'aide d'outils d'intelligence artificielle externes (ChatGPT, DALL-E, Midjourney ou tout autre générateur de son choix), les importe sur la plateforme, et chaque image validée par le système lui rapporte 25 FCFA. En accumulant des gains, une caution et des parrainages, il débloque l'accès à des micro-prêts de 5 000 ou 10 000 FCFA. Autour de ce noyau gravitent des modules complémentaires : parrainage, niveaux d'investissement, roue de la fortune, trading simulé avec arène de

classement, chat avec assistant IA et support humain, guide pédagogique complet et panneau d'administration.

Le public visé est mobile : l'application est construite comme une application de type téléphone (cadre vertical de 430 pixels maximum), avec une barre de navigation basse à six entrées (Tableau, Accueil, Finance, Portefeuille, Guide, Profil), installable comme application progressive (PWA) sur l'écran d'accueil du smartphone. La langue de l'interface est intégralement le français.

2.2 Stack technique et architecture

La plateforme est une application monopage Next.js 16 (App Router) écrite en React 19 et TypeScript, stylée avec Tailwind CSS 4 et la bibliothèque de composants shadcn/ui. Les données sont persistées dans une base SQLite via Prisma ORM ; l'état côté client est géré par Zustand ; le temps réel du chat s'appuie sur Socket.io via un mini-service séparé ; les courriels de vérification passent par Resend, Gmail ou un mode simulation selon la configuration. L'application expose environ 80 routes d'API réparties par domaine (auth, missions, prêts, dépôts, retraits, invest, jeu, trading, chat, admin, notifications, parrainage) et une vingtaine d'écrans chargés dynamiquement pour des performances optimales.

Tableau 1 : composants techniques principaux et leur rôle

Composant	Rôle dans le système
Next.js 16 + React 19	Cadre applicatif, rendu des écrans, routes d'API (app/api)
TypeScript	Typage statique de tout le code applicatif
Tailwind CSS 4 + shadcn/ui	Interface visuelle et composants réutilisables
Prisma ORM + SQLite	Persistance des utilisateurs, soldes, images, prêts, transactions
Zustand	État global côté client (session, page courante, notifications)
Socket.io (mini-service)	Temps réel du chat entre jeunes, bot et administrateur
Resend / Gmail / simulation	Envoi des codes de vérification par courriel
PWA (manifest + service worker)	Installation sur mobile, mode hors-ligne partiel

2.3 Données et monnaies internes

Le schéma de données distingue plusieurs soldes par utilisateur : solde principal, solde missions, solde jeu, solde d'investissement, solde de projet et solde de trading. Les récompenses de missions sont libellées en FCFA mais enregistrées en dollars américains

dans la base, à partir d'un taux de conversion configurable par l'administrateur (cfaUsdRate) ; l'interface reconvertit à l'affichage. Cette double devise est un point de vigilance comptable détaillé au chapitre 5. Les autres objets persistés incluent les campagnes de mission, les images soumises avec leur statut de validation, la caution, les prêts et leurs remboursements, les dépôts en attente (YAS, TRX, mobile money), les retraits, les filleuls, les niveaux d'investissement, les notifications et l'historique complet des transactions.

3. Parcours d'entrée : inscription, OTP et connexion

3.1 Création de compte

L'entrée dans la plateforme se fait par l'écran d'authentification, qui offre deux modes : connexion et inscription. L'inscription exige un nom complet, une adresse électronique, un mot de passe d'au moins six caractères confirmé deux fois et un numéro de téléphone ; un code de parrainage peut être saisi facultativement, ce qui lie le nouveau compte à son parrain. Le serveur vérifie l'unicité de l'adresse et du téléphone, génère un code de parrainage propre au nouveau compte, puis crée l'enregistrement utilisateur avec un jeton de session provisoire. À ce stade, le compte n'est pas encore actif : il reste marqué non vérifié jusqu'à la confirmation du courriel.

3.2 Vérification par code à usage unique (OTP)

La plateforme envoie immédiatement un code à six chiffres à l'adresse indiquée. Ce code est valable dix minutes, et il est stocké en base sous forme hachée (SHA-256), jamais en clair. Trois canaux d'envoi sont prévus selon la configuration : le fournisseur Resend, un compte Gmail, ou un mode simulation qui affiche le code directement à l'écran — c'est ce mode qui est actif lorsque aucune clé d'API n'est configurée, ce qui est le cas de l'environnement de développement actuel. Dès que le jeune saisit le bon code, le compte est marqué vérifié et surtout le jeton de session est régénéré : toute session ouverte avant la vérification devient invalide. Ce mécanisme de rotation est une protection anti-fraude bien conçue, volontairement discrète dans l'interface.

3.3 Connexion et gestion des sessions

La connexion compare le mot de passe soumis à celui enregistré (voir le chapitre 5 pour le problème de stockage en clair), puis délivre un jeton de session de 32 caractères hexadécimaux aléatoires, déposé dans un cookie nommé `br_token` valable sept jours. Chaque nouvelle connexion régénère ce jeton : un compte ne peut donc pas rester connecté simultanément sur deux appareils, l'ancien appareil est silencieusement déconnecté. Les routes d'API authentifient chaque requête par ce jeton, via l'en-tête `X-Auth-Token` ou le cookie, et les réponses serveur ne renvoient jamais le mot de passe ni le jeton dans les

données utilisateur. Le même parcours existe pour la récupération de mot de passe : un code est envoyé par courriel, une page de réinitialisation protégée permet d'en définir un nouveau.

Après connexion, l'utilisateur arrive directement sur l'écran « Tableau », point d'entrée du tableau de bord décrit au chapitre suivant. Une page d'accueil promotionnelle (splash) affiche le logo et la promesse du service pendant le chargement, et l'application propose son installation sur l'écran d'accueil du téléphone via le manifeste PWA.

4. Fonctionnement détaillé des modules

Ce chapitre décrit le comportement réel de chaque module, dans l'ordre du parcours type d'un jeune : lecture du tableau de bord, réalisation de missions, constitution de l'éligibilité au prêt, gestion du portefeuille, croissance par le parrainage et l'investissement, divertissement, assistance, et enfin pilotage côté administrateur. Les règles et montants cités sont ceux du code et de la configuration administrative actuelle.

4.1 Tableau de bord du jeune (Étape 1)

Le tableau de bord est la première page visible après la connexion. Il a été reconstruit conformément à la spécification « Étape 1 » : salutation personnalisée (« Bonjour, prénom »), quatre cartes statistiques (solde disponible, gains du jour, compteur d'images 7/10 avec barre de progression, parrainages 3/5), grande carte d'objectif vers 2 500 FCFA avec pourcentage et reste à gagner, carte d'éligibilité au prêt de 5 000 FCFA listant chaque condition remplie ou non, carte « Ma caution » au cadenas distincte du solde, missions disponibles avec bouton « Voir la mission » (jamais « Générer », la création d'image se faisant à l'extérieur du site), bloc pédagogique « Comment gagner ? » en cinq étapes, et activité récente avec historique.

À ce stade, ces données sont volontairement fictives afin de valider le design ; elles sont structurées exactement comme les réponses des API existantes (missions/dashboard, missions/campaigns, referral/list), de sorte que le remplacement par les vraies données de la base se fera sans refonte de l'interface. La navigation interne du tableau de bord offre sept entrées : Tableau, Missions, Mes images, Portefeuille (raccourci vers l'écran portefeuille), Éligibilité, Mes prêts et Parrainage. L'en-tête permanent affiche le logo « Jeune Élan », la cloche de notifications (compteur de non-lues rafraîchi toutes les quinze secondes) et l'accès au profil.

4.2 Missions rémunérées et validation par intelligence artificielle

Une mission correspond à une campagne créée par l'administrateur : marque, nom, brief créatif, format attendu, style, contraintes, récompense (25 FCFA par image validée), limite quotidienne par jeune (10 images par jour) et volume maximal global. Le jeune consulte le brief, crée son image avec l'outil d'intelligence artificielle de son choix en dehors de la

plateforme, puis l'importe : l'image est envoyée en base 64, enregistrée avec une empreinte de similarité, et le jeune peut suivre son compteur journalier. Le compteur se réinitialise chaque jour.

La validation est asynchrone et automatique. Le système transmet l'image à un modèle de vision par API, qui évalue la conformité au brief, l'originalité, l'absence de doublon et le caractère non téléchargé d'internet. Cinq statuts en résultent : en attente, validée (+25 FCFA crédités sur le solde missions), refusée, doublon (image trop similaire à une soumission précédente) et non conforme. Chaque décision est notifiée au jeune avec le motif ; les images non retenues ne rapportent rien. Les images sont purgées quotidiennement pour libérer l'espace de stockage, tandis que les gains restent acquis dans l'historique des transactions. Ce module est le cœur du modèle : c'est lui qui transforme le temps du jeune en monnaie interne, et c'est donc lui qui détermine la charge financière décrite au chapitre 6.

4.3 Objectif 2 500 FCFA, caution et micro-prêts

Le parcours de crédit est balisé par trois conditions cumulatives. Premièrement, le jeune doit cumuler au moins 2 500 FCFA de gains issus exclusivement des missions validées — la progression vers cet objectif ignore volontairement les dépôts personnels, la caution et l'argent d'un prêt, conformément à la règle du programme. Deuxièmement, il doit bloquer une caution de 5 000 FCFA, montant sécurisé, affiché au cadenas et explicitement exclu du solde disponible au retrait. Troisièmement, il doit compter 5 parrainages validés (seuil du petit prêt). Le tableau d'éligibilité affiche en permanence ces conditions avec leur état, le niveau de confiance de l'utilisateur (Débutant, Actif, Éligible, Fiable) et un bouton d'action qui devient « Demander un prêt » une fois tout rempli.

Deux formats de prêt existent : 5 000 FCFA (conditions ci-dessus) et 10 000 FCFA (conditions renforcées). La demande enregistrée passe par une file d'attente ; elle est approuvée manuellement par l'administrateur, devient active avec une échéance à 30 jours, puis passe en remboursement partiel ou total. Aucun intérêt n'est prélevé par le code : le prêt est remboursé à montant nominal. Les statuts gérés couvrent l'ensemble du cycle : en attente, approuvé, actif, en remboursement, en retard, remboursé et refusé, avec notifications à chaque transition et blocage de toute nouvelle demande tant qu'un prêt est actif ou en retard. L'éligibilité ne garantit donc pas l'octroi : la décision finale reste administrative.

4.4 Portefeuille, dépôts et retraits

Le portefeuille agrège l'ensemble des avoirs du jeune sur des comptes séparés : compte principal, compte missions, compte jeu, compte investissement et compte projet, avec solde total, gains cumulés, pertes cumulées et historique complet des transactions. Les mouvements internes (récompenses, gains de jeu, rendements, bonus, prêts) alimentent les

comptes correspondants sans jamais se mélanger avec les dépôts d'origine externe, ce qui facilite la traçabilité.

Les dépôts externes transitent par trois canaux : le portefeuille YAS, le réseau TRX (Tron) avec adresse de dépôt et vérification on-chain via un explorateur, et le mobile money. Tout dépôt est d'abord enregistré en attente, puis crédité après validation manuelle par l'administrateur ; un seul dépôt en attente est autorisé simultanément. Le premier dépôt validé déclenche une condition de sécurité : le jeune doit attendre 24 heures avant de pouvoir demander un retrait. Les retraits sont soumis à validation administrative et à un dispositif anti-abus particulier : le nombre de parrainages requis augmente avec le nombre de retraits déjà effectués, ce qui rend chaque retrait successif plus exigeant. Les fonds sortent vers le canal choisi, avec une conversion TRX vers mobile money le cas échéant. Ce verrou progressif est présenté au chapitre 6 pour ce qu'il est : un frein à la sortie de trésorerie qui retarde les engagements mais ne les crée pas.

4.5 Parrainage et niveaux d'investissement

Chaque utilisateur reçoit un code de parrainage unique, consultable et copiable depuis l'écran dédié. Un filleul est comptabilisé lorsqu'il s'inscrit avec ce code ; il devient « validé » lorsqu'il devient actif (dépôt effectué). Le parrain touche un bonus de 20 % par filleul validé et les parrainages servent de clé de déblocage dans tout le système : 5 pour le petit prêt, 12 pour le niveau 2 d'investissement, 25 pour le niveau 3, et un nombre croissant pour déverrouiller les retraits successifs. Le parrainage est donc le moteur de croissance virale de la plateforme — et en même temps, comme chaque filleul actif génère du passif de missions, l'agent d'accroissement du passif.

Le module d'investissement propose trois niveaux libellés en dollars : niveau 1 « Débutant » de 5 à 15 \$ (sans parrainage requis), niveau 2 « Business » de 65 à 250 \$ (12 parrainages), niveau 3 « Elite » de 500 à 3 000 \$ (25 parrainages). Chaque placement rapporte 5 % de son montant, collectables quotidiennement (« collecte quotidienne illimitée » selon l'interface). Cette mécanique, vérifiée dans la route de réclamation, est le paramètre financier le plus explosif du système : un placement de 3 000 \$ émet théoriquement 150 \$ par jour. Les conséquences sont analysées au chapitre 6.

4.6 Jeu, trading et arène

La roue de la fortune dispose de douze segments : gains de 0,10 à 10,00 \$ et cases perdantes. Chaque tour a un coût, prélevé sur le compte jeu ; le jeune dispose de dix tours par jour et le résultat du tirage est déterminé côté serveur, ce qui interdit la triche côté client. Les gains alimentent le compte jeu, consultable et retirable selon les mêmes règles que les autres comptes.

Le trading est une simulation de marché : cours, graphiques, ouverture et fermeture de positions sur le solde de trading dédié, avec historique des gains et pertes. L'arène ajoute une dimension compétitive en classant les meilleurs traders de la plateforme. Ces modules n'émettent pas de monnaie externe : ils font circuler les soldes internes et augmentent l'engagement quotidien, mais leurs gains s'ajoutent au passif global dès qu'ils deviennent retirables.

4.7 Chat, support et notifications

Le centre d'assistance combine un assistant conversationnel automatisé (réponses immédiates sur le fonctionnement, les missions, les prêts et les dépôts) et une escalade vers un humain : le jeune peut ouvrir un ticket, échanger en temps réel avec l'administrateur via Socket.io, et clôturer la conversation. L'administrateur répond depuis son panneau et peut gérer les conversations ouvertes. Le système de notifications couvre la vie du compte : validation ou refus d'image, seuils atteints, statut de prêt, statut de dépôt et de retrait, messages de diffusion collective envoyés par l'administration. La cloche affiche le compteur de non-lues avec un rafraîchissement toutes les quinze secondes, et une notification du jour s'affiche sur l'écran d'accueil.

4.8 Guide, PWA et éléments annexes

L'écran Guide rassemble une pédagogie complète en huit chapitres : créer un compte, choisir une mission, générer l'image avec une IA externe, l'importer, comprendre la validation, gérer son argent, utiliser le parrainage et sécuriser son compte (le guide rappelle notamment que la plateforme ne demande jamais le mot de passe). L'application est une PWA complète : manifeste, icônes, service worker et invite d'installation sur l'écran d'accueil. Un bandeau de rappel de rafraîchissement et un bandeau de retraits récents complètent l'expérience. Les anciens modules de plateforme vidéo, retirés de l'interface lors des travaux précédents, laissent des routes d'API résiduelles à nettoyer (annexe).

4.9 Panel administrateur

Le panneau d'administration n'est visible que des comptes de rôle admin et s'ouvre depuis le profil. Il couvre : la gestion des utilisateurs (consultation, ajustement manuel des soldes, transfert de fonds, suppression), la validation des dépôts YAS et TRX, le traitement des demandes de retrait, la création et la modification des campagnes de mission (brief, récompense, limites), la réponse aux conversations de support, l'envoi de notifications individuelles ou de diffusions collectives, les statistiques d'activité (analytics) et la configuration globale du programme : taux de conversion FCFA/dollar, récompense par image, seuils des prêts, montant de la caution et conditions de parrainage. Ce panneau est le point de contrôle de toutes les règles décrites dans ce chapitre ; il est aussi, en l'état, protégé

par les faiblesses d'authentification décrites au chapitre suivant, ce qui en fait la cible la plus sensible du système.

5. Analyse de sécurité : failles identifiées et correctifs

L'objectif de ce chapitre est de permettre à l'administrateur d'analyser le système sans laisser de faille exploitable. L'analyse distingue d'abord ce qui est déjà solide, puis recense les vulnérabilités par ordre de gravité, chacune rattachée à son fichier et à son correctif concret. Aucune faille listée ici n'est théorique : toutes ont été constatées dans le code du dépôt.

5.1 Mécanismes de sécurité existants et efficaces

Plusieurs dispositifs sont correctement implémentés et méritent d'être conservés. Les jetons de session sont des valeurs aléatoires de 32 caractères hexadécimaux, régénérées à chaque connexion et à chaque vérification de courriel : ce mécanisme de rotation invalide automatiquement les sessions volées ou obsolètes et empêche la connexion simultanée d'un même compte sur plusieurs appareils. Les codes de vérification sont valables dix minutes et stockés hachés en SHA-256, jamais en clair. Les réponses d'API excluent systématiquement le mot de passe et le jeton des données renvoyées au client. Les montants critiques (niveaux d'investissement, plafonds de mission, conditions de prêt, coût et gains de la roue) sont calculés et contrôlés côté serveur, et le tirage de la roue est déterminé côté serveur. Enfin, l'affichage dynamique du texte utilise une fonction d'échappement protectrice contre l'injection de scripts (XSS) dans les zones sensibles.

5.2 Failles identifiées, impact et correctifs

Le tableau ci-dessous hiérarchise les failles constatées. Deux d'entre elles sont critiques : elles exposent l'intégralité du système à quiconque lit le code source public du dépôt GitHub, et doivent être corrigées avant toute mise en production ou toute communication autour du projet.

Tableau 2 : registre des vulnérabilités constatées dans le code

Gravité	Faille constatée	Impact concret	Correctif recommandé
Critique	Compte administrateur codé en dur dans la route de connexion : adresse et mot de passe en clair dans le code source, sur un dépôt GitHub public	Toute personne lisant le dépôt obtient le contrôle total : soldes, retraits, suppression d'utilisateurs	Supprimer le compte en dur ; créer l'admin en base avec rôle et mot de passe haché ; réécrire l'historique du secret ; changer le mot de passe

Gravité	Faille constatée	Impact concret	Correctif recommandé
Critique	Mots de passe des utilisateurs stockés en clair dans la base de données	Toute fuite de la base compromet tous les comptes, avec réutilisation probable des mots de passe sur d'autres services	Hacher avec bcrypt ou argon2 à l'inscription ; migration progressive à la prochaine connexion ; jamais de mot de passe en clair ni dans les logs
Élevée	Aucune limitation de débit sur les routes d'authentification et d'OTP	Bombardement de courriels, force brute des mots de passe et des codes, coût d'API	Limitation par IP et par compte (ex. 5 tentatives / 10 minutes), temporisation croissante, journalisation des échecs
Élevée	Cookie de session sans indicateur httpOnly ni secure	Un script injecté (XSS résiduel) ou une interception HTTP permet de voler la session	Activer httpOnly, secure en production, conserver sameSite lax ; envisager la liaison au périphérique
Élevée	Téléphone demandé à l'inscription mais jamais vérifié ; aucun contrôle anti-multi-comptes	Auto-parrainage massif par création de comptes, fraude aux bonus de 20 % et aux seuils	Vérification par SMS (OTP téléphone), détection d'adresses IP et d'empreintes partagées, plafonnement des bonus par appareil
Moyenne	Images soumises stockées en base 64 dans SQLite	Gonflement rapide de la base (une image = plusieurs centaines de Ko), sauvegardes lourdes, ralentissements	Stockage objet (fichiers ou S3) avec identifiant en base ; compression à l'import ; purge déjà prévue à conserver
Moyenne	Validation d'image heuristique : empreinte limitée aux premiers caractères, détection d'images d'internet non garantie	Soumissions recyclées ou copiées rémunérées à tort, dilution du passif de missions	Empreinte perceptuelle (pHash) sur l'image décodée, comparaison par lot, vérification de provenance par IA renforcée
Moyenne	Base SQLite unique en production, sans sauvegarde automatisée identifiée	Perte de données irréversible, interruption de service, litiges de soldes non prouvables	Sauvegardes quotidiennes chiffrées hors site ; bascule PostgreSQL (compatible Prisma) avant montée en charge
Moyenne	Double devise FCFA/dollar gérée par un taux configurable, sans journal de conversion	Écarts d'arrondi, soldes contestables, comptabilité invérifiable	Journaliser chaque conversion (date, taux, montants), arrondi réglementé, taux figé par jour

Gravité	Faible constatée	Impact concret	Correctif recommandé
Faible	Code mort (routes vidéo résiduelles), fichiers temporaires volumineux dans le répertoire de travail (captures, journaux d'outils, téléversements)	Surface d'attaque et confusion inutiles, dépôt alourdi	Supprimer les routes mortes, ajouter les exclusions au contrôle de version, nettoyer le répertoire
Faible	Jeton d'accès GitHub personnel manipulé en clair pendant les travaux	Compromission du dépôt si le jeton a fuité	Révoquer le jeton immédiatement et en créer un neuf à usage restreint

5.3 Plan de correction priorisé

La correction recommandée suit l'ordre de gravité. Avant toute ouverture au public : suppression du compte administrateur en dur (avec réécriture du secret dans l'historique du dépôt et changement du mot de passe), hachage bcrypt des mots de passe avec migration transparente à la prochaine connexion, et activation de httpOnly/secure sur le cookie de session. Dans la foulée : limitation de débit sur toutes les routes d'authentification, vérification SMS du téléphone et contrôles anti-multi-comptes orientés parrainage. Dans un second temps : migration des images vers un stockage objet, sauvegarde quotidienne chiffrée, journal des conversions de devise, puis nettoyage du code mort. Chaque correctif est localisé (un à trois fichiers), compatible avec l'architecture actuelle et réalisable sans refonte.

6. Analyse de viabilité financière pour l'administrateur

La question posée est directe : l'administrateur va-t-il couler, ou le projet sera-t-il rentable sur le long terme ? La réponse exige d'abord de recenser où l'argent entre réellement, où il sort, puis de chiffrer le déséquilibre, avant d'examiner sous quelles conditions le modèle peut devenir viable.

6.1 Où l'argent entre — et où il ne rentre pas

Trois flux font entrer de l'argent réel sur la plateforme : les dépôts des jeunes (YAS, TRX, mobile money), les cautions de 5 000 FCFA et les placements d'investissement (5 à 3 000 \$). Ces flux sont des dettes envers les utilisateurs, pas des revenus : chaque franc déposé reste exigible. En face, les dépenses réelles de l'administrateur sont les retraits validés, les frais de transaction mobile money et blockchain, les coûts d'hébergement et de domaine, les appels d'API de validation d'images et de messagerie, et le temps de modération humaine. Le point

décisif est le suivant : le code ne contient aucune source de revenu. Aucune commission sur retrait, aucun frais de dossier sur prêt (remboursés à montant nominal), aucun sponsor payant rattaché aux campagnes de mission, aucune publicité vendue — les bandeaux publicitaires affichés lors des changements d'onglet ont été supprimés et étaient de toute façon fictifs, sans régie ni contrat. Le seul « produit » de la plateforme, le visuel publicitaire créé par le jeune, n'est monétisé nulle part : il est payé sans être vendu.

6.2 Le problème structurel : un passif qui croît sans revenu

Chaque activité de la plateforme crée de la dette envers les utilisateurs : 25 FCFA par image validée, les gains de la roue (jusqu'à 10 \$ par tirage), le bonus de 20 % par filleul validé, et surtout le rendement de 5 % par jour des investissements — un placement de niveau 3 à 3 000 \$ émet théoriquement 150 \$ chaque jour, soit plus de 1 000 \$ par semaine, sans qu'aucun actif réel ne produise ces montants. Comme aucune entrée de revenu ne compense ces émissions, la position de trésorerie de l'administrateur ne peut mathématiquement que se dégrader avec chaque utilisateur actif. Les verrous actuels (délai de 24 heures après le premier dépôt, parrainages requis croissants à chaque retrait, validation manuelle des retraits) ne suppriment pas cette dette : ils la rendent simplement plus lente à se matérialiser, tout en l'aggravant au passage puisque les parrainages exigés pour retirer génèrent eux-mêmes du passif de missions. Un tel montage, où les dépôts des nouveaux arrivants servent à honorer les retraits des anciens, est de plus structurellement assimilable à un schéma de type pyramide : il fonctionne tant que la croissance des entrées dépasse les sorties, puis s'effondre au premier ralentissement.



Figure 1 : passif hebdomadaire généré par les seules missions (25 F par image, 7 images validées par jour et par jeune), selon le nombre de jeunes actifs

À titre d'ordre de grandeur, 500 jeunes actifs au rythme moyen de sept images validées par jour représentent à eux seuls 61 875 FCFA de récompenses par jour, soit environ 1,9 million par mois et 31,9 millions par an. Ce passif précède même les frais fixes : chaque appel de validation d'images, chaque courriel et chaque heure de modération s'ajoutent par-dessus. La figure 1 montre la progression de cette charge avec la taille de la communauté — la croissance, loin de résoudre le problème, l'amplifie linéairement.

6.3 Scénarios d'évolution chiffrés

Les scénarios ci-dessous illustrent, à communauté constante de 500 jeunes actifs, l'effet de trois stratégies sur le résultat brut annuel de l'administrateur (récompenses de missions uniquement, avant frais fixes et avant les émissions de jeu, parrainage et investissement). Ils reposent sur les paramètres réels du code et des hypothèses de sponsor explicitées ; ce sont des projections illustratives, non des données observées.

Tableau 3 : scénarios annuels comparés à 500 jeunes actifs (illustratif)

Scénario	Hypothèses	Revenus annuels	Passif missions	Résultat brut
A. Statu quo	Aucun revenu activé, fonctionnement actuel du code	0 FCFA	31,9 M FCFA	-31,9 M FCFA
B. Sponsors de marques	30 % des images sponsorisées à 75 FCFA payés par la marque (soit 383 000 visuels achetés dans l'année)	28,7 M FCFA	31,9 M FCFA	-3,2 M FCFA
C. Modèle diversifié	Sponsors 30 % à 75 FCFA, frais de service de 3 % sur retraits et frais de dossier de 5 % sur prêts (volumes estimés)	36,0 M FCFA	31,9 M FCFA	+4,1 M FCFA

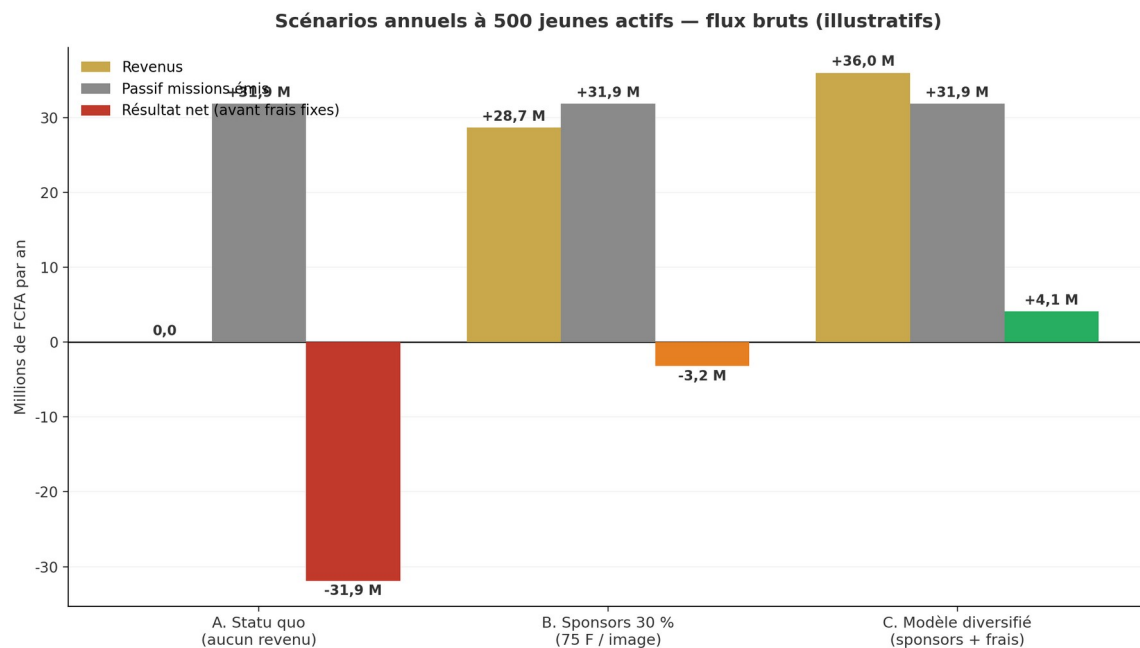


Figure 2 : comparaison des trois scénarios annuels (millions de FCFA) — le résultat net du scénario C reste fragile face aux émissions de jeu, de parrainage et d'investissement non incluses

La lecture des scénarios est claire. Le statu quo (A) cumule un déficit de plus de 31 millions de FCFA par an avant même les frais d'exploitation, et coule dès que les retraits s'accumulent au rythme des gains. Le scénario B, où des marques paieraient réellement trois visuels sur dix à 75 FCFA, reste légèrement déficitaire sur le seul périmètre missions : il montre que le sponsoring seul, à un taux de couverture réaliste, ne suffit pas. Seul le scénario C — sponsoring combiné à des frais de service (retraits, dossiers de prêt) — franchit le seuil de rentabilité brut, avec une marge volontairement mince : rappelons que les émissions de la roue, des bonus de parrainage et des rendements d'investissement de 5 % par jour, non incluses dans ce calcul, effaceraient cette marge si elles n'étaient pas supprimées ou plafonnées. La conclusion opérationnelle est double : il faut activer des revenus réels, et simultanément éteindre les émissions non couvertes, en premier lieu le rendement quotidien de 5 %.

6.4 Risques réglementaires et réputationnels

Trois risques non financiers pèsent lourd sur la viabilité. Réglementaire d'abord : collecter des dépôts et des cautions, accorder du crédit et convertir des monnaies sont, dans l'ensemble de la zone UEMOA régie par la BCEAO, des activités réservées aux établissements agréés (microfinance, monnaie électronique, services de paiement) ; exploiter ces services sans agrément expose l'administrateur à des sanctions et à la responsabilité personnelle des fonds collectés. Ce dossier ne remplace pas un avis juridique, mais le sujet doit être traité avant toute mise en production grand public, par exemple via un partenariat avec un établissement agréé ou un repositionnement du produit hors du crédit et de la collecte. Réputationnel ensuite : promettre des gains réels que la trésorerie ne peut honorer transforme rapidement les

délais de retrait en litiges publics, avec un effet catastrophique sur le recrutement de nouveaux jeunes dont dépend précisément la trésorerie. Opérationnel enfin : la fraude multi-comptes (auto-parrainage) et les soumissions d'images copiées diluent les budgets de récompense sans produire de valeur monétisable pour un futur sponsor.

6.5 Verdict : couler ou être rentable ?

En l'état actuel du code, sans revenu activé et avec des émissions non couvertes, le projet coulera : la trésorerie ne peut que baisser, les verrous de retrait ne font que retarder l'échéance tout en l'aggravant, et le risque réglementaire s'ajoute au risque financier. Le projet n'est toutefois pas condamné par sa technologie, qui fonctionne, ni par son concept d'engagement, qui produit un actif réel — une communauté de jeunes capables de produire des visuels publicitaires. Il est condamné uniquement par l'absence de monétisation de cet actif. La rentabilité à long terme est atteignable à trois conditions cumulatives, détaillées au chapitre suivant : activer des revenus réels (sponsors de marques payant à l'image, frais de service raisonnables et assumés), plafonner ou supprimer les émissions non couvertes (rendement de 5 % par jour, gains de roue retirables, bonus de parrainage monétaires), et régler le statut réglementaire des activités de dépôt et de crédit. Sans ces trois conditions, le scénario A s'impose ; avec elles, le scénario C devient crédible et scalable.

7. Conclusions et plan d'action recommandé

Le système « Jeune Élan » est techniquement fonctionnel et complet : le parcours d'entrée par OTP est robuste, le cœur métier missions-éligibilité-prêts est cohérent, l'interface est soignée et le panneau d'administration couvre l'ensemble des paramètres du programme. Les faiblesses identifiées ne relèvent pas de l'architecture mais de deux décisions de sécurité (mot de passe en clair, compte administrateur en dur) et d'un modèle économique inachevé (un passif émis sans revenu en face). Le plan d'action ci-dessous consolide l'ensemble des recommandations de ce dossier en trois horizons.

Tableau 4 : plan d'action consolidé et priorisé

Horizon	Actions prioritaires	Résultat attendu
Immédiat (avant toute ouverture publique)	Supprimer l'administrateur codé en dur et changer le secret ; hacher les mots de passe (bcrypt) ; activer httpOnly/secure sur le cookie ; limiter le débit des routes d'authentification ; révoquer le jeton GitHub exposé	Surface d'attaque critique fermée ; base et dépôt non compromis

Horizon	Actions prioritaires	Résultat attendu
Court terme (1 à 3 mois)	Remplacer les données fictives du tableau de bord par les API ; vérification SMS et contrôles anti-multi-comptes ; sauvegardes quotidiennes chiffrées ; suppression du rendement de 5 %/jour et plafonnement des gains retirables ; journal des conversions de devise	Fraude contenue ; passif maîtrisé ; données recouvrables
Moyen terme (3 à 6 mois)	Signer des sponsors de marques réels payant à l'image (objectif : couvrir au moins 30 % des visuels) ; introduire des frais de service transparents sur retraits et dossiers de prêt ; statuer sur la conformité réglementaire (partenariat agréé ou recentrage du produit) ; basculer vers PostgreSQL et un stockage objet des images	Revenus réels actifs ; modèle proche du scénario C ; trajectoire de rentabilité crédible

La recommandation finale tient en une phrase : ne pas ouvrir la plateforme au public dans son état actuel, corriger d'abord les deux failles critiques, puis faire du chapitre 6 une règle de gouvernance — aucune émission de gains sans revenu correspondant en face. Tant que cette équation n'est pas respectée, chaque nouveau jeune actif rapproche l'administrateur de l'insolvabilité ; dès qu'elle l'est, la communauté devient au contraire l'actif le plus précieux du projet.

Annexe : cartographie des modules et principales routes d'API

Cette annexe sert de référence rapide pour l'audit et la maintenance : chaque module fonctionnel est rattaché à ses routes d'API réelles dans le dépôt, ce qui permet de localiser immédiatement le code correspondant à toute règle décrite dans ce dossier. Les routes obsolètes (plateforme vidéo retirée de l'interface) sont signalées pour nettoyage.

Tableau 5 : modules et routes d'API correspondantes

Module	Routes principales	Observations
Authentification	/api/auth/register, /api/auth/otp, /api/auth/login, /api/auth/session, /api/auth/logout, /api/auth/forgot- password, /api/auth/reset- password	OTP haché ; rotation du jeton de session ; failles critiques à corriger (chapitre 5)

Module	Routes principales	Observations
Missions	/api/missions/dashboard, /campaigns, /images, /validate, /eligibility, /caution	Validation IA asynchrone ; 25 FCFA par image ; limite 10/jour ; purge quotidienne
Prêts	/api/missions/loans, /api/missions/loans/[id]	5 000 et 10 000 FCFA ; échéance 30 jours ; approbation administrative ; sans intérêt
Portefeuille et transactions	/api/transfer, /api/notifications	Comptes séparés principal/missions/jeu/investisse- ment/projet
Dépôts	/api/deposit, /api/deposit/yas, /api/deposit/trx, /api/deposit/check	En attente jusqu'à validation admin ; un seul dépôt en attente à la fois
Retraits	/api/withdrawal, /api/withdrawal/yas, /api/withdrawal/convert-trx- tmoney	Délai de 24 h après premier dépôt ; parrainages requis croissants ; validation admin
Parrainage	/api/referral/list	Code unique ; bonus de 20 % ; seuils 5 / 12 / 25 selon les usages
Investissements	/api/invest/list, /create, /claim, /unlock	3 niveaux en dollars ; rendement 5 %/jour à supprimer (chapitre 6)
Jeu	/api/game/spin, /api/game/status	Roue 12 segments ; tirage serveur ; 10 tours/jour
Trading et arène	/api/trading/prices, /positions, /open-position, /close-position, /history, /leaderboard, /chart ; /api/trade/*	Simulation de marché ; classement compétitif
Chat et support	/api/chat/bot, /send, /messages, /ticket, /escalate, /tip	Assistant IA puis escalade humaine ; temps réel Socket.io
Administration	/api/admin/data, /users/[id], /update-balance, /transfer- funds, /delete-user, /campaigns, /withdrawals, /deposits, /yas-deposits, /notifications, /send- notification, /broadcasts, /chats, /chat-reply, /support, /config, /analytics	Contrôle total du programme ; cible la plus sensible (chapitre 5)
Notifications	/api/notifications, /api/notifications/daily	Compteur non-lues ; notification du jour ; diffusion collective
Obsolète	/api/videos/*, /api/projects/*, /api/enterprise/*, /api/gains/*	Plateforme vidéo retirée de l'interface ; routes résiduelles à supprimer

Pour toute évolution future du tableau de bord (Étape 2 et suivantes de la spécification), les données fictives actuellement en place sont calquées sur les réponses des routes missions/dashboard, missions/campaigns et referral/list : le remplacement se fait donc point par point, sans modification de l'interface ni des autres modules.